LAB 5 - PaketPro 3000: SBOM / CVE / Patch

Çıktı: Zafiyet kararı (Vulnerability Decision); Evidence Pack EP 09, 10 ve 11.

Kavramlar

SBOM, yazılım malzeme listesidir. CVE, açığın kayıt numarasıdır. CVSS, ciddiyet puanıdır (0-10). Etkilenme için bileşenin bulunması, sürümün açık kapsamında olması ve açığın erişilebilir olması kontrol edilir.

Verilen zafiyet kaydı

Alan	Föy bilgisi
Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

CVE-XXXX-XXXX, föydeki örnek kimliktir.

Görev - Karar akışı

1. Bu CVE bizi gerçekten etkiliyor mu?

Henüz kesin olarak bilinmiyor; Component X'in sistemde bulunması, 2.4 sürümünün CVE'den etkilenmesi ve açığın erişilebilir olması durumunda sistem etkilenir.

2. Üretimi hemen durdurur musunuz? Neden?

Hemen durdurmam; önce CVSS 9.8 seviyesindeki açığın oluşturduğu risk değerlendirilir ve çalışan güvenliğini tehdit ediyorsa üretim durdurulur.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Yama doğrudan uygulanmaz; önce izole test ortamında denenir, PLC, HMI ve emniyet fonksiyonlarına etkisi kontrol edildikten sonra uygulanır.

4. Bu yama safety validation'ı etkiliyor mu? Nasıl anlarsınız?

Etkileyebilir; ışık perdesi, Safety PLC ve STO zinciri test edilerek emniyet fonksiyonlarının doğru çalıştığı doğrulanır.

5. Yama mümkün değilse telafi edici önlem ne olur?

Etkilenen PLC ağ üzerinden izole edilir, uzak bakım erişimi sınırlandırılır ve güvenlik duvarı kuralları sıkılaştırılır. Sistem izlenerek yama uygulanana kadar risk azaltılır.

Kaynaklar

• INSPECCO × KRIPTARIUM, PaketPro 3000 LAB Föyleri: LAB 5, PDF s. 6.